

Vendor Acknowledgment of Security Report

arifOS — SSRF in `arif_fetch` (private-IP check fails open)

REPORTER	Syed Anas Mohiuddin
VENDOR / PROJECT	arifOS — github.com/ariffazil/arifOS · arifos.arif-fazil.com
MAINTAINER CONTACT	Muhammad Arif bin Fazil < arifbfazil@gmail.com >
DATE REPORTED	25 August 2026 (private disclosure; no public detail at any point)
DATE FIXED IN SOURCE	25 August 2026 — commits 285a956d8 , e2759cf4b , 22586943f
DATE RELEASED PUBLICLY	15 September 2026, 16:23 UTC — PyPI <code>arifos 1!2026.9.1</code>
AFFECTED VERSIONS	all published builds $\leq 1!2026.8.2$
FIXED VERSIONS	<code>1!2026.9.1</code> and later — <code>pip install arifos</code>
VENDOR POSITION	Report confirmed as a true positive. Fix shipped and independently re-tested.

1. What was reported

- **Primary path.** `arif_fetch` validated the target URL by string inspection only. A URL such as `http://0.0.0.0:PORT/` was not recognised as private; the request was made and the response body was returned to the caller.
- **Fallback path.** On a primary fetch error, the handler re-fetched the same URL through a second code path that performed no equivalent validation — i.e. the check failed open rather than closed.
- **Adjacent surfaces.** The reporter also identified a peer-contract URL passed to `urlopen` without validation, and an unwired fetch helper carrying the same weakness.

2. Fix shipped

A single shared guard now mediates every fetch path: `arifosmcp/runtime/ssrf_guard.py`. It applies a scheme allowlist, blocks local names, classifies literal IPs with `ipaddress` (including non-dotted notations such as `2130706433` and `0x7f000001`, and IPv4-mapped IPv6), and performs full DNS resolution with every returned address checked against private, loopback, link-local (including `169.254.169.254`), reserved, multicast and unspecified ranges. Any risk flag is fail-closed: no fetch path — primary, fallback, render or redirect — proceeds. Redirects are followed by a bounded hop loop that re-runs the guard on each hop.

3. Verification after the fix

Re-tested against both the source tree and the published PyPI artifact (`arifos 1!2026.9.1`), with identical results. Blocked as `private_ip_access` or `scheme_blocked`: `0.0.0.0`, `127.0.0.1`, `2130706433`, `0x7f000001`, `:::1`, `:::ffff:127.0.0.1`, `localhost`, `10.0.0.5`, `192.168.1.1`, the cloud metadata address `169.254.169.254`, and the `file:///` / `gopher://` schemes. Public URLs (`example.com`, `api.github.com`, `pypi.org`) continue to resolve as permitted.

Note on availability. Until 15 September 2026 the fix existed on the repository's main branch but the published PyPI artifact was still the pre-fix build — `pip install arifos` would have installed `1!2026.8.2`. The release pipeline has since been repaired and `1!2026.9.1` is live, so the fixed code is now what the package index serves.

4. Residual risk (documented, accepted)

Validation resolves the hostname at check time, not at connect time, so a DNS-rebinding time-of-check/time-of-use window remains in principle. This is documented in the guard module, accepted for the current release because the MCP surface binds to localhost by default, and the planned remediation is pinning the resolved IPs into the transport.

5. Disclosure route and credit

arifOS is not a CNA and does not maintain a bug-bounty programme. The vendor supports the reporter filing this finding directly with MITRE as the reporter of record. This document is issued as the vendor's written confirmation for that submission. The finding is credited to Syed Anas Mohiuddin, and the fix commits carry an external-report reference.

Provenance. arifOS is maintained by one human maintainer who directs AI engineering agents; the code and the verification described above were produced by those agents under the maintainer's accountability. This statement is the maintainer's.
Issued 16 September 2026 · Muhammad Arif bin Fazil · arifbfazil@gmail.com